

Seven Principles of Data Protection and Individuals' Rights

The General Data Protection Regulation (GDPR) identifies seven key principles that guide how organisations collect, use and store personal data.

1. Lawfulness, fairness and transparency¹

In order to process data lawfully, organisations must identify one or more specific legal grounds for processing, known as a 'lawful basis'. There are six lawful bases: consent, contract, legal obligation, vital interests, public task and legitimate interests. No one basis is preferable to or supersedes another – it's up to the organisation to decide which basis or bases apply, depending on the purpose for which the data is collected and the company's relationship with the individual. This lawfulness principle also applies in a more general legal sense to include obligations based on breaches of statute and common law – such as committing a criminal offence, copyright infringement or breaching a contract.

'Fairness' means processing data in ways that people would reasonably expect, without unjustified adverse effects. This principle partly depends on how data is obtained. For example, if an individual is deceived or misled when their data is acquired, its use is likely to be unfair.

'Transparency' is linked to fairness in that individuals must be informed about how their data will be used in a way that's accessible, honest, clear and easy to understand. For instance, a website must alert you to the data it collects on you when you use the website, and in most cases you must provide permission for data collection to take place.

2. Purpose limitation

Personal data must be collected for specified, explicit and legitimate purposes only. This means two things. First, organisations have to be clear about why they're collecting personal data. And second, what they intend to do with it needs to align with the reasonable expectations of those from whom the data has been collected.

As well as specifying and communicating these purposes, organisations must also comply with legal obligations to document the purposes.² If they then want to use the data for a different purpose, they must ask for consent to do so, unless there is another legal reason to justify the change of use. For example, if a company wants to use customer sales data for marketing purposes, it must ask individual customers for permission. If the organisation uses the data outside of its original purpose and fails to get consent, this is breaking the law.

¹ Information Commissioner's Office (2025). Principle (a): Lawfulness, fairness and transparency. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/lawfulness-fairness-and-transparency/> [Accessed 8 May 2025]

² Information Commissioner's Office (N.D.). Documentation. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/documentation/> [Accessed 8 May 2025]

3. Data minimisation

Organisations must hold only the personal data that is relevant to a predetermined, lawful and specified purpose – and nothing beyond this. As such, personal data gathered must be limited to what is necessary to carry out the specified task and companies can't decide to track as much personal data as they wish, only what they need for the particular reason. Therefore, it wouldn't be acceptable to ask a job applicant to share personal information that has no bearing on the job.

Organisations must also ensure that they have sufficient personal data to properly fulfil their purposes, regularly review the data they hold and delete anything that isn't needed.

4. Accuracy

Data collected should be accurate and not misleading in any way. But there is also a requirement to think about ways that personal data could become inaccurate. For example, if an employee is dismissed for misconduct, but subsequently exonerated, their HR record must be updated to reflect this. Organisations need to take reasonable steps to update data so that it is accurate.

5. Storage limitation

This principle concerns how long organisations can retain personal data. This will vary, but needs to be justified by the company's purpose for using the data in the first place. Data that is no longer relevant or required should be erased or anonymised, unless it needs to be held for legal reasons or in the public interest, such as being historically important.

As a rule, personal data should not be held for longer than necessary. This means that stored data must be regularly reviewed to determine whether it's still needed. Organisations should also have a policy that outlines standard retention periods where possible, in line with documentation obligations.

6. Integrity and confidentiality

Also known as the 'security' principle, organisations must ensure that they take the necessary steps to keep data confidential, intact and secure. This also applies to retrieving data – companies need to have measures in place to restore access to data when it has been lost.

Security can't be assumed. Organisations must carry out risk assessments to determine whether their data storage arrangements and related policies are fit for purpose. The GDPR also sets out standards for detecting and handling data breaches, including those that involve actual loss or theft of data.

7. Accountability

This covers all of the principles already examined. As data controllers, organisations must demonstrate that they've taken responsibility for compliance with the GDPR, and have appropriate measures and records in place to show this.

Alongside the seven principles, the law also gives individuals eight 'rights' regarding the collection, use and storage of their data, which mirror the principles above. These include rights related to being informed, access, rectification, erasure, restricted processing, portability, objection, and automated decision-making, which includes profiling.³ Companies must honour these rights in the ways that they process data and respond to individuals' requests for access. Three of the most important rights are explored in more detail below.

- **Right to be informed**

Individuals have the right to be informed about the collection, use and storage of their personal data. As established, organisations need to let people know – clearly and simply – why they're processing personal data, as well as its retention periods and who it will be shared with. This is typically called 'privacy information' – often contained in privacy notices on websites or attached to emails. This information needs to be communicated at the point of data collection.

- **Right of access**

Individuals have the right to access and receive a copy of the personal data held on them, and understand how an organisation is using it. This is often called a 'subject access request' (SAR). This right also covers employees who want to access the personal data that their employer holds on them, such as interview notes or payroll details. Individuals are not usually required to pay a fee to access or receive their personal data. They can request access verbally or in writing (including through social media), and the company must respond within one month.

- **Right to erasure**

Also known as the 'right to be forgotten', individuals can request that personal data held about them is erased in certain circumstances. For example, consent as a lawful basis being withdrawn, or the data is no longer necessary for its original purpose – such as a former employee asking their ex-employer to delete any personal data held on them. However, this right is not absolute. For instance, if the organisation needs to process the individual's data to comply with its legal obligations (e.g. disclosing salary details to HMRC), the organisation can refuse the erasure request.⁴

³ Information Commissioner's Office (N.D.). A guide to individual rights. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/> [Accessed 8 May 2025]

⁴ Information Commissioner's Office (N.D.). A guide to individual rights. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/> [Accessed 8 May 2025]